

Stoquify Agent CI and Release Evidence Capture Runbook

Date: 2026-07-25

Scope: Agent Runtime Phase 2A immutable CI and frozen release identity

Activation authority: None

Phase 3 authority: None

Purpose

This runbook defines the provider-neutral contract for capturing a clean CI result and immutable release identity from an authenticated build/release attestation system.

The collector proves that:

- invalid authentication is rejected;
- the attestation endpoint uses query-free HTTPS;
- the source tree was clean;
- CI passed no more than 24 hours ago;
- the attestation was generated after CI completed and no more than 24 hours ago;
- package, commit, artifact, deployment, manifest, evidence bundle, browser report, and allowlists are bound together;
- the package has immutable `PILOT_CERTIFIED` proof and is not activated;
- release and CI evidence share the same sanitized capture hash;
- only `release` and `ci` can be changed.

The collector cannot change governance, approvals, owners, scheduler evidence, alert evidence, credential rotation, declared status, or activation.

Required Configuration

Configure these values through the deployment configuration and managed secret systems:

```
STOQUIFY_AGENT_CI_RELEASE_EVIDENCE_URL=https://<attestation-host>/<path>
STOQUIFY_AGENT_CI_RELEASE_EVIDENCE_SECRET=<managed-secret-minimum-32-characters>
STOQUIFY_AGENT_RELEASE_ENVIRONMENT=internal_pilot
STOQUIFY_AGENT_CI_RELEASE_EVIDENCE_TIMEOUT_MS=20000
```

The URL must:

- use HTTPS outside local development;
- contain no embedded credentials, query string, or fragment;
- expose `GET` with bearer authentication;
- return `401` for an invalid bearer value;
- return only the sanitized contract below for an authorized request.

Attestation Contract

```
{
  "ok": true,
  "data": {
    "ready": true,
    "environment": "internal_pilot",
    "sourceSystemReference": "ci-system://stoquify/internal-pilot",
    "attestationReference": "attestation://agent-runtime/ci/release-1",
    "attestationDigest": "sha256:<64-hex-characters>",
    "attestedAt": "2026-07-25T13:25:00.000Z",
    "release": {
      "packageId": "<package-id>",
      "releaseVersion": "<release-version>",
      "packageState": "PILOT_CERTIFIED",
      "commitSha": "<40-or-64-hex-characters>",
      "artifactDigest": "sha256:<64-hex-characters>",
      "artifactReference": "artifact://stoquify/<release>",
      "deploymentReference": "deployment://internal-pilot/<release>",
      "packageCertificationReference": "certification://agent-runtime/<package>",
      "packageCertificationHash": "sha256:<64-hex-characters>",
      "manifestHash": "sha256:<64-hex-characters>",
      "evidenceBundleHash": "sha256:<64-hex-characters>",
      "browserReportHash": "sha256:<64-hex-characters>",
      "pilotAllowlistReference": "policy://pilot/tenants/<version>",
      "roleAllowlistReference": "policy://pilot/roles/<version>",
      "activatedAt": null
    },
    "ci": {
      "status": "PASSED",
      "sourceTreeClean": true,
      "commitSha": "<same-commit>",
      "branchReference": "git://stoquify/<branch>",
      "runReference": "ci://stoquify/runs/<id>",
      "artifactDigest": "sha256:<same-artifact>",
      "artifactReference": "artifact://stoquify/<same-release>",
      "browserReportHash": "sha256:<same-browser-report>",
      "completedAt": "2026-07-25T13:20:00.000Z"
    }
  }
}
```

Source Requirements

The evidence endpoint must be backed by an immutable CI or release attestation system. Suitable sources include a protected release workflow, artifact provenance service, or deployment attestation service.

The following are inadmissible:

- a dirty local worktree;
- an uncommitted source snapshot;
- a mutable artifact without a digest;
- screenshots in place of a CI run reference;
- a browser report from another commit or artifact;
- a package certification created after activation;
- query-bearing or signed URLs copied into the evidence register;
- a CI result older than 24 hours.

Capture Procedure

1. Freeze a reviewed clean commit.
2. Run CI from that exact commit.
3. Produce the immutable application artifact and digest.
4. Run the sanitized enabled-pilot browser certification against that artifact.
5. Create or verify the inactive `PILOT_CERTIFIED` package.
6. Bind package, artifact, deployment, manifest, evidence bundle, browser report, tenant allowlist, and role allowlist.
7. Publish the immutable CI/release attestation.
8. Expose only the sanitized contract.
9. Run:

```
npm run agent:ci-release:evidence:report
```

10. Inspect the generated JSON and Markdown under `what-next/agents-runtime/`.
11. Apply a ready capture:

```
npm run agent:ci-release:evidence:apply
```

12. Capture governance after the release identity is frozen:

```
npm run agent:governance:evidence:apply
```

13. Re-run:

```
npm run agent:operational-release:gate
```

Fail-Closed Rules

The collector refuses to update the register when:

- the endpoint is missing, non-HTTPS, query-bearing, unavailable, oversized, or malformed;
- invalid authentication does not return `401`;
- the attested environment differs from the register;
- CI failed or the source tree was not clean;

- CI completion or the attestation is future-dated or older than 24 hours;
- the attestation predates CI completion;
- commit, artifact, artifact reference, or browser-report hashes differ between release and CI;
- package certification proof is absent or malformed;
- the package is not `PILOT_CERTIFIED`;
- activation is present in the attestation or operational register;
- a nonempty release identity in the register differs from the capture.

Retained Evidence

The collector retains:

- value-free CI, artifact, deployment, certification, allowlist, and attestation references;
- immutable hashes and commit identity;
- clean-tree, CI status, completion, and attestation timestamps;
- the SHA-256 hash of the sanitized capture;
- invalid-auth and environment-match outcomes.

It does not retain:

- bearer values or authorization headers;
- raw CI logs or HTTP responses;
- environment snapshots;
- signed URLs or artifact credentials;
- source archives;
- tenant or business data.

Current Preflight

The repository preflight was executed without an external CI attestation endpoint and correctly returned:

```
{
  "ok": false,
  "code": "CI_RELEASE_EVIDENCE_URL_MISSING",
  "activationAuthorized": false,
  "secretValuesPrinted": false
}
```

No CI, release, package, or activation evidence was fabricated or updated.